TxShield: Transaction-level RAG-enabled DeFi Attack Detection

ANONYMOUS AUTHOR(S)

Decentralized Finance (DeFi) protocols have become prime targets for sophisticated attacks, with losses exceeding $3.4 billion in 2025. However, existing detection approaches face fundamental limitations. Traditional rule-based detection tools are limited in their ability to capture diverse attack behaviors at runtime, while advanced large language models (LLMs) exhibit extrinsic limitations due to knowledge staleness and hallucinations. To this end, we observe that DeFi attacks, despite diverse implementations, exhibit recurring behavioral patterns at the semantic level, suggesting that their apparent diversity masks a small number of underlying semantic structures. In this paper, we present TxShield, a Retrieval-Augmented Generation framework for real-time DeFi attack detection. TxShield constructs an incrementally expandable knowledge base of historical attacks with LLM-generated behavioral summaries, employs a two-stage retrieval mechanism with dynamic similarity thresholding to select relevant historical context, and applies adaptive prompting to guide LLM reasoning by analogy with retrieved patterns. An XGBoost post-filter checks the attack candidates produced by the LLM before the system returns its final result.

On 728 transactions, TxShield with Kimi-k3 achieves 92.93% F1 and 97.87% precision. Compared with direct XGBoost classification, it improves F1 by 6.45 percentage points and reduces false positives from 60 to 7. With the same backbone, the complete system exceeds the no-XGBoost variant by 14.99 F1 points. The retrieval ablation identifies a more specific trade-off: without XGBoost, two-stage retrieval increases precision but reduces recall and F1.

CCS Concepts: • **Software and its engineering → Software testing and debugging**; • **Security and privacy → Software security engineering**.

Additional Key Words and Phrases: Smart Contract Security, DeFi Attack Detection, Retrieval-Augmented Generation, Transaction Analysis, Blockchain Security

ACM Reference Format:
Anonymous Author(s). 2026. TxShield: Transaction-level RAG-enabled DeFi Attack Detection. In *Proceedings of ACM SIGSOFT International Symposium on Software Testing and Analysis (ISSTA '26)*. ACM, New York, NY, USA, 25 pages. https://doi.org/XXXXXXX.XXXXXXX

1 Introduction

Decentralized Finance (DeFi) has emerged as a major application of blockchain technology, enabling permissionless financial services through smart contracts. By late 2025, the total value locked (TVL) in DeFi protocols had exceeded $230 billion, reflecting the substantial financial value managed by DeFi systems [43]. This rapid growth has attracted a large user base, with tens of millions of users interacting with DeFi protocols worldwide. The increasing scale of DeFi has been accompanied by significant security challenges. Industry analyses report that losses from cryptocurrency hacks and exploits exceeded $3.4 billion in 2025, with DeFi protocols representing a major attack surface [1, 2]. These attacks span both traditional smart-contract vulnerabilities, such as reentrancy as seen in the DAO incident, and advanced economic exploits that leverage flash loans to manipulate prices

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than the author(s) must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.
ISSTA '26, TBD
© 2026 Copyright held by the owner/author(s). Publication rights licensed to ACM.
ACM ISBN 978-1-4503-XXXX-X/2026/07
https://doi.org/XXXXXXX.XXXXXXX

and protocol states within a single transaction [31]. The immutable nature of smart contracts exacerbates these risks. Once deployed, vulnerabilities cannot be patched retroactively, making effective testing and continuous post-deployment monitoring critical for mitigating security threats in DeFi systems.

Existing approaches to smart contract security can be broadly categorized into four paradigms, each with inherent limitations. *Static analysis tools* such as Slither [11] and Mythril [10] use pattern matching and symbolic execution to identify known vulnerability patterns. While effective at detecting classic bugs such as reentrancy, these tools suffer from path explosion in complex contracts and often struggle to capture runtime behaviors or cross-protocol interactions arising from DeFi composability [49]. *Formal verification frameworks* like Certora Prover [19] and KEVM [18] provide mathematical guarantees but require substantial manual effort to specify invariants and often struggle to model the dynamic, multi-protocol nature of DeFi. *Rule-based dynamic detection tools* such as DeFiRanger [39], DeFiTainter [30], and DeFort [42] analyze transaction traces to detect price-manipulation attacks. However, these approaches rely on predefined mathematical models of specific pricing mechanisms (e.g., constant-product AMMs), making them less effective for custom protocols with non-standard price models; DeFiScope reports that such custom price models account for 44.2% of 95 real-world price manipulation attacks collected over the past three years [48]. *LLM-based approaches* represent a recent paradigm shift. TrxGNNBERT [24] leverages a graph-transformer language model to learn trace-level representations for DeFi fraud detection, while GPTScan [33] combines GPT with static analysis for logic-vulnerability detection and iAudit [25] employs fine-tuned models with multi-agent debate for source-code auditing. However, these methods either focus primarily on pre-deployment source-code analysis and cannot detect runtime attacks, or incur high end-to-end overhead for trace construction and model inference, limiting practicality for real-time monitoring. LLM hallucinations can lead to plausible but incorrect vulnerability reports. Moreover, parametric knowledge quickly becomes outdated as attack patterns evolve.

Our key insight, distilled from years of practical experience in smart-contract security, is that DeFi attacks, despite their diverse manifestations, often exhibit recurring behavioral patterns at the semantic level. For example, a price manipulation attack typically follows a "borrow, manipulate, and profit" sequence: obtaining large capital via flash loans, executing trades that artificially inflate or deflate token prices, and extracting profit before repaying the loan, all within a single atomic transaction. This observation suggests that historical attack cases, annotated with behavioral semantics, can serve as a valuable knowledge source to guide the detection of new attacks. To empirically ground this insight, we analyze approximately 200 real-world DeFi attack incidents from DeFiHackLabs [34]. Despite their apparent diversity, these attacks consistently fall into eight major semantic categories, with Business Logic Flaws, Price Manipulation, and Reentrancy-based call attacks dominating the incident landscape. These results provide quantitative evidence that attack patterns are reusable across different protocols.

However, realizing this insight poses three technical challenges: **(C1) Semantic Gap:** Raw execution traces consist of low-level EVM operations and function calls that are difficult to interpret. *How can we bridge the gap between low-level traces and high-level attack semantics?* **(C2) Retrieval Precision:** Naïve similarity search may retrieve irrelevant or misleading historical cases, introducing noise that can degrade detection accuracy. *How can we ensure that retrieved cases are truly relevant to the query transaction?* **(C3) Reasoning Reliability:** Even with relevant context, LLMs may hallucinate or fail to correctly apply retrieved knowledge. *How can we guide the LLM to make reliable attack-or-benign decisions?*

To address these challenges, we propose TxShield, a Retrieval-Augmented Generation framework for the DeFi transaction attack detection. At a high level, TxShield comprises two main

components: a *Historical Knowledge Base* and a *RAG-based Decision Engine*. For **C1**, we construct an incrementally expandable knowledge base by collecting execution traces from historical attack incidents, extracting behavioral summaries using LLM-based semantic summarization, and storing them as vector embeddings alongside structured metadata. This transforms opaque execution traces into interpretable attack patterns. For **C2**, we design a two-stage retrieval mechanism: the first stage performs vector similarity search to retrieve top-k candidate cases; the second stage applies a dynamic similarity threshold ($\tau = 0.85$) to filter out low-confidence matches, ensuring that only highly relevant cases are used as context. For **C3**, we employ an adaptive prompting strategy: when high-similarity historical cases exist, we construct an augmented prompt that instructs the LLM to reason by analogy with the retrieved attack patterns; otherwise, the system falls back to zero-shot analysis based solely on the transaction data. The LLM first identifies attack candidates, which are then filtered by XGBoost using numerical transaction features.

We evaluate TxShield on DeFiAttackBench, a balanced set of 728 transactions. With Kimi-k3, the system achieves 92.93% F1, compared with 86.48% for XGBoost-only, and reduces false positives from 60 to 7. The Kimi variant without XGBoost achieves 77.94% F1. Across the three complete post-filtered backbone evaluations, F1 ranges from 89.45% to 92.93%. The complementary PriceAttackBench evaluation detects 86 of 91 attacks (94.51%). These experiments examine both general transaction detection and specialized price-manipulation detection.

This paper makes the following contributions:

- We present TxShield, the first RAG-based framework for the DeFi transaction attack detection that leverages historical attack knowledge to enhance LLM reasoning, addressing the limitations of both rule-based and pure LLM approaches.
- We design a detection pipeline that retrieves historical attack evidence for LLM reasoning and applies XGBoost to filter the resulting attack candidates.
- We evaluate detection on 728 transactions, including a direct XGBoost baseline, Kimi-based ablations, and three complete LLM backbone evaluations. The combined system improves F1 and reduces false positives relative to direct numerical classification.
- We characterize the strengths and limitations of trace-based semantic reasoning across attack categories, identifying the behavioral evidence that supports detection and the contextual requirements that limit it.

Roadmap. Section 2 introduces the background. Section 3 details the design of TxShield, including knowledge base construction, two-stage retrieval, adaptive prompting, and XGBoost post-filtering. Section 6 presents our experimental evaluation and ablation studies, Section 7 demonstrate the related work and Section 8 concludes with limitations and future directions.

2 Background

Smart Contracts and DeFi Ecosystem. Smart contracts are self-executing programs deployed on blockchain platforms such as Ethereum. Written primarily in Solidity, these contracts are compiled into bytecode and executed by the Ethereum Virtual Machine (EVM), a stack-based virtual machine that processes transactions deterministically across all network nodes. Once deployed, smart contract code is immutable (it cannot be modified or patched), which makes security vulnerabilities particularly consequential. Decentralized Finance (DeFi) leverages smart contracts to replicate traditional financial services without centralized intermediaries [49]. The DeFi ecosystem comprises several key protocol types: (1) *Decentralized Exchanges (DEXs)* such as Uniswap [4] enable permissionless token trading through Automated Market Makers (AMMs), where liquidity pools and mathematical formulas (e.g., the constant-product formula $x \cdot y = k$) determine token prices; (2) *Lending Protocols* like Aave [3] and Compound allow users to lend and

borrow assets with interest rates determined algorithmically; and (3) *Flash Loan Providers* offer uncollateralized loans that must be borrowed and repaid within a single atomic transaction [31]. A defining characteristic of DeFi is *composability* (the ability for protocols to interact seamlessly, with outputs from one protocol serving as inputs to another). While composability enables capital efficiency and innovation, it also creates complex attack surfaces where vulnerabilities can span multiple protocols.

DeFi Attack Taxonomy. Based on existing literature [8, 28, 49], we categorize DeFi attacks into the following major types:

Reentrancy Attacks. Reentrancy occurs when a contract makes an external call to another contract before updating its own state, allowing the callee to "re-enter" the original function and exploit the inconsistent state [14]. Modern variants include cross-function reentrancy (exploiting state shared across multiple functions) and cross-contract reentrancy (exploiting interactions between multiple contracts) [37, 44].

Price Manipulation Attacks. These attacks exploit the mechanism by which DeFi protocols determine asset prices. In AMM-based DEXs, an attacker can execute large trades to temporarily shift the price curve, then exploit this artificial price in another protocol (e.g., a lending platform using the DEX as a price oracle) [39, 41]. Flash loans amplify this threat by providing attackers with massive capital at zero upfront cost [31]. Time-Weighted Average Price (TWAP) oracles, designed to mitigate single-block manipulation, remain vulnerable to multi-block attacks [26].

Access Control Vulnerabilities. These vulnerabilities arise when privileged functions lack proper authorization checks, allowing unauthorized users to execute administrative operations such as minting tokens, modifying parameters, or draining funds [33]. Variants include missing access modifiers, incorrect role assignments, and unprotected initialization functions.

Business Logic Flaws. Unlike generic vulnerability patterns, business logic flaws are protocol-specific bugs in the implementation of intended functionality. Examples include incorrect reward calculations, flawed liquidation mechanisms, and improper handling of edge cases. These vulnerabilities are particularly challenging to detect because they require understanding the protocol's intended behavior [25].

Other Vulnerabilities. Additional attack vectors include integer overflow/underflow (largely mitigated by Solidity 0.8+), front-running and sandwich attacks exploiting transaction ordering [7], and governance attacks manipulating decentralized voting mechanisms.

Retrieval-Augmented Generation. Retrieval-Augmented Generation (RAG) is a paradigm that enhances LLM capabilities by incorporating external knowledge retrieval [22]. Unlike pure parametric models that rely solely on knowledge encoded in their weights during training, RAG systems dynamically retrieve relevant information from external databases to augment the generation process. A typical RAG architecture consists of three components: (1) a *knowledge base* storing documents as vector embeddings, (2) a *retriever* that identifies relevant documents given a query, and (3) a *generator* (typically an LLM) that produces outputs conditioned on both the query and retrieved context. The retrieval process typically employs dense vector similarity search, where queries and documents are mapped to a shared embedding space and relevance is measured by cosine similarity or other distance metrics. RAG addresses two fundamental limitations of standalone LLMs. First, it mitigates *knowledge staleness*: while LLM parameters are fixed after training, the knowledge base can be continuously updated with new information. Second, it reduces *hallucination*: by grounding generation in retrieved evidence, RAG systems produce more factually accurate outputs [47]. These properties make RAG particularly suitable for domains requiring up-to-date, specialized knowledge, such as detecting rapidly evolving DeFi attack patterns.

3 Approach Overview

This section presents the design of TxShield, a retrieval-augmented framework for real-time DeFi attack detection. We first provide an overview of the system architecture and then detail each component: the historical knowledge base construction pipeline, the two-stage retrieval mechanism, adaptive LLM-based reasoning, and XGBoost post-filtering.

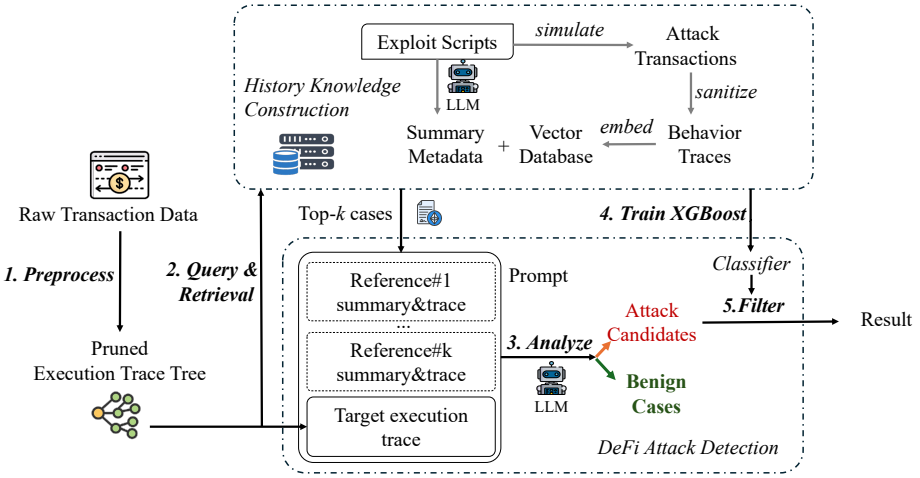


Fig. 1. A high-level overview of TxShield

As illustrated in Figure 1, TxShield comprises two main components that work in tandem to detect DeFi attacks.

The *Historical Knowledge Base* serves as an external memory that stores structured representations of past attack incidents. Unlike static rule sets, this knowledge base captures behavioral semantics—high-level descriptions of how attacks unfold—enabling TxShield to recognize novel attack variants that share similar patterns with known incidents. The knowledge base can be incrementally expanded as new attacks are discovered and analyzed.

The *RAG-based Decision Engine* processes incoming transactions through a pipeline that (1) extracts and normalizes execution traces, (2) retrieves relevant historical cases via similarity search, (3) applies a dynamic threshold to filter retrieval results, and (4) constructs prompts for LLM-based attack analysis. The LLM first produces an initial decision; XGBoost then filters the attack candidates to produce the final result. The engine adapts its behavior based on retrieval results: when high-similarity historical cases exist, it leverages them for analogical reasoning; otherwise, it falls back to zero-shot analysis.

This architecture addresses the three challenges identified in Section 1: the knowledge base construction bridges the semantic gap (C1) by transforming low-level traces into interpretable summaries; the two-stage retrieval addresses context selection (C2) by filtering candidate cases; and the adaptive prompting strategy enhances reasoning reliability (C3) by grounding LLM decisions in relevant evidence.

4 Security Knowledge Construction

The knowledge base construction pipeline transforms raw historical attack data into a searchable repository of behavioral patterns. The constructions encompass three stages: execution trace minimization, semantic summarization, and vector indexing.

We source historical attack incidents from DeFiHackLabs [34], a curated repository containing Proof-of-Concept (PoC) implementations of real-world DeFi exploits. The historical knowledge base contains 209 entries. Each PoC is a Foundry [29] test case that reproduces the attack on a forked blockchain state. For each incident, we execute the PoC and collect:

- Invocation Flow: The sequence of external and internal function calls, including contract addresses, function signatures, and call parameters.
- State Changes: Modifications to contract storage, particularly balance changes for relevant tokens.
- Event Logs: Emitted events that signal significant operations (e.g., `Transfer`, `Swap`, `Borrow`).
- Metadata: Attack date, affected protocol, estimated loss, and attack type labels (when available).

The raw trace data captures the very execution details of an attack but often lacks the semantic context needed for effective analysis. To eliminate execution noise and reduce the trace size, we apply a minimization algorithm that removes redundant or low-information nodes while preserving the essential control-flow and asset-flow semantics of the attack.

4.1 Execution Trace Minimization

Raw execution traces are often complicated and verbose, resulting in overly too large context bases for LLM to reason efficiently and effectively in limited context windows. Our investigation reveals that exploit transactions exhibit similar execution patterns. First, most of them have manipulated balance of contract accounts, through the operations like *send* or *transfer*. Second, many of them involve complex contract interactions through external calls, such as *flashloan* that borrows a large amount of tokens from a lending protocol. With these observations, we devise an algorithm to filter out likely unuseful items within raw execution traces while preserving attack semantics.

As shown in Algorithm 1, the minimization process consists of three stages: duplicate removal, general pruning, and target-oriented pruning. First, we identify repeated call nodes through a depth-first traversal (Lines 10-17). A call is represented by a signature tuple *<type, contract, function, args, value, return>* indicating its call type, contract address, function name, arguments, transferred value, and return value (Line 11). Within each trace tree, only the first occurrence of a signature is retained (Line 15); subsequent occurrences and their subtrees are removed during pruning stage (Lines 19-20).

Second, we recursively apply general pruning and normalization rules (Lines 18-34). Nodes beyond the maximum traversal depth are replaced by truncation markers to preserve the existence of deeper execution while bounding the trace size (Lines 22). We remove only low-information static metadata queries, namely calls associated with `decimals`, `symbol`, and `name` (Lines 23-24). In contrast, other state-dependent queries such as `balanceOf` and `getReserves`, as well as event nodes, are retained because they may expose asset-flow or protocol-state evidence. Long argument strings are truncated to a fixed length, and contract addresses are converted to compact aliases while preserving their distinguishing prefixes and suffixes (Lines 31-33).

Finally, we perform target-oriented structural pruning if target function(s) are given. After locating the target function f_t, such as `executeOperation`, we record the depth of its first occurrence (Line 6). At that depth, nodes that do not invoke f_t are removed, whereas nodes at other depths remain subject only to the general pruning rules (Line 8, Lines 35-41). This step suppresses parallel calls that are less relevant to the monitored execution phase while retaining the context leading to the target call and its nested internal behavior. The resulting minimized tree reduces redundant and low-information content while preserving control-flow, asset-flow, and state-query evidence relevant to attack monitoring.

Algorithm 1: Execution Trace Tree Minimization

Input: Execution trace tree $\mathcal{T}$ with root r; target function f_t; maximum depth $D_{\max}$; maximum argument length $L_{\max}$
Output: Minimized execution trace tree $\mathcal{T}'$

$\mathcal{S} \leftarrow \emptyset$; // Set of previously observed call signatures
MarkDuplicates$(r, \mathcal{S})$;
$r' \leftarrow$ GeneralPrune$(r, 0, D_{\max}, L_{\max})$;
if $r' = \varnothing$ **then**
  return $\emptyset$;
$(P, d_t) \leftarrow$ FindDeepestTarget(r', f_t);
; // P indicates a deepest call path to the target function f_t at depth d_t
if *P exists* **then**
  PruneTargetLevel(r', d_t, f_t);
return the tree rooted at r';
Function `MarkDuplicates`$(v, \mathcal{S})$**:**
  $\sigma(v) \leftarrow \langle v.type, v.contract, v.function, v.args, v.value, v.return \rangle$;
  if $\sigma(v) \in \mathcal{S}$ **then**
    $v.duplicate \leftarrow$ true;
  else
    $\mathcal{S} \leftarrow \mathcal{S} \cup \{\sigma(v)\}$;
  foreach $u \in v.children$ **do**
    MarkDuplicates$(u, \mathcal{S})$;
Function `GeneralPrune`$(v, d, D_{\max}, L_{\max})$**:**
  if $v.duplicate =$ true **then**
    return $\varnothing$;
  if $d > D_{\max}$ **then**
    return TruncatedNode(d);
  if $v.type =$ `STATICCALL` ***and*** IsMetadataQuery$(v.function)$ **then**
    return $\varnothing$;
  $C' \leftarrow \emptyset$;
  foreach $u \in v.children$ **do**
    $u' \leftarrow$ GeneralPrune$(u, d+1, D_{\max}, L_{\max})$;
    if $u' \neq \varnothing$ **then**
      $C' \leftarrow C' \parallel u'$;
  $v.children \leftarrow C'$;
  if $|v.args| > L_{\max}$ **then**
    $v.args \leftarrow$ Prefix$(v.args, L_{\max}) \parallel$ <truncated>;
  $v.contract \leftarrow$ AliasAddress$(v.contract)$;
  return v;
Function `PruneTargetLevel`(v, d_t, f_t)**:**
  $C' \leftarrow \emptyset$;
  foreach $u \in v.children$ **do**
    if $u.depth \neq d_t$ ***or*** $u.function = f_t$ **then**
      PruneTargetLevel(u, d_t, f_t);
      $C' \leftarrow C' \parallel u$;
  $v.children \leftarrow C'$;

4.2 Semantic Summarization and Vector Indexing

Raw execution traces are verbose and difficult to interpret directly. We use an LLM to generate concise *behavioral summaries* that describe the attack logic in natural language. The summarization prompt instructs the model to:

(1) Identify the attack type (e.g., price manipulation, reentrancy, access control).
(2) Describe the attack flow in 3–5 steps, focusing on the sequence of operations and their effects.
(3) Highlight key indicators: unusual fund movements, suspicious call patterns, or state manipulation.
(4) Note the vulnerability exploited and how it was triggered.

For example, a flash-loan price manipulation attack might be summarized as: *"The attacker borrows 10 M USDC via an Aave flash loan, swaps to ETH on Uniswap to inflate the ETH/USDC price, deposits ETH as collateral on the victim lending protocol (which uses Uniswap as a price oracle), borrows the maximum amount of USDC against the inflated collateral value, repays the flash loan, and profits $2.3 M from the price discrepancy."* These summaries provide human-readable documentation and, more importantly, distill the semantic essence of attacks into a concise form that offers more useful context for downstream analysis and retrieval.

Each attack case is stored as a record containing: (1) a unique case ID, (2) the behavioral summary, (3) the raw execution trace, and (4) structured metadata. We generate vector embeddings for the behavioral summaries using a pre-trained text embedding model and index them in a vector database. The vector representation enables semantic similarity search: when a new transaction exhibits patterns similar to known attacks, relevant historical cases can be retrieved even if the specific contracts, function names, or token addresses differ. This "semantic fingerprinting" is the foundation of TxShield's generalization capability.

5 In-Context Reasoning for Attack Detection

Naïve similarity search can retrieve cases that are superficially similar but semantically irrelevant, introducing noise that degrades detection accuracy. We design a two-stage retrieval mechanism to ensure high-precision context for LLM reasoning.

5.1 Knowledge Retrieval

Given an incoming transaction, TxShield first preprocesses it to extract the execution trace and generates a query representation. This query is embedded using the same model as the knowledge base, and we perform approximate nearest neighbor search to retrieve the top-k most similar historical cases. We compute pairwise similarity based on the L2 distance in the embedding space: $\text{sim}(q, d) = 1 - \|q - d\|_2$, where q is the query embedding and d is a document embedding from the knowledge base. Higher scores indicate greater semantic similarity. We set $k = 5$ to balance recall and computational efficiency.

Not all retrieved cases are equally relevant. To filter out low-confidence matches, we apply a similarity threshold τ: $C_{\text{filtered}} = \{d_i \in \text{Top-}k \mid \text{sim}(q, d_i) \geq \tau\}$. We empirically set $\tau = 0.85$ based on validation experiments that examined the correlation between similarity scores and detection accuracy. Cases below this threshold are discarded to prevent the LLM from being misled by tangentially related examples.

This two-stage mechanism serves as a "quality gate": Stage 1 casts a wide net to capture potentially relevant cases, while Stage 2 refines the results to retain only high-confidence matches. If no cases satisfy the threshold ($C_{\text{filtered}} = \emptyset$), TxShield proceeds without retrieval augmentation.

Prompt template for retrieval-augmented detection

Input:
* Current transaction: {system_input}
* Historical attack examples: {reference_attack}

You are an expert in smart contract attack detection. Your task is to analyze the Current transaction against Historical attack examples provided in the context to determine malicious intent.
The historical examples were retrieved due to high behavioral similarity to the current transaction. Therefore, you must assume malicious intent initially and focus on validating the attack pattern.
Following the instructions:
1. Start assuming this is an Attack executing a known pattern.
2. Compare execution flow and fund transfers with historical examples.
3. Ignore function names; focus on operational sequence and security implications.
4. Focus on Inter-contract calls, abnormal fund movements, state manipulation patterns.

Output MUST begin with a short answer 'Attack' or 'Benign', followed by below information:
1. *Behavior Summary*: Describe contract interactions, fund movements, and final goal.
2. *Comparative Call Sequence Analysis*: Analyze call sequence. Compare with most similar historical ID(s). State shared malicious steps.
3. *Malicious Indicators & Similarity Assessment*: Identify attack-confirming behaviors. Rate similarity: High/Moderate/Low. If Benign, provide irrefutable evidence.

Fig. 2. Prompt template for retrieval-augmented detection.

5.2 Adaptive LLM-Based Reasoning

The final component leverages an LLM to analyze the transaction and make an attack-versus-benign decision. We employ an adaptive prompting strategy that varies based on the retrieval results.

When closely matching historical cases are retrieved ($C_{\text{filtered}} \neq \emptyset$), we construct an augmented prompt that includes:

(1) A *role definition* establishing the LLM as an expert in smart contract attack detection.
(2) The *current transaction*, i.e., the execution trace of the transaction under analysis.
(3) *Historical context*: behavioral summaries and metadata of retrieved cases, with case IDs mapped to detailed security descriptions.
(4) *Analysis instructions* directing the LLM to compare the current transaction against historical patterns, identify shared malicious indicators, and assess the degree of behavioral correspondence.

The prompt instructs the LLM to *assume initial suspicion* given the proximity to known attack patterns, and to provide irrefutable evidence if concluding the transaction is benign. Concretely, a `Benign` verdict is accepted only when it is supported by explicit, trace-grounded evidence that provides concrete evidence against the malicious hypothesis suggested by retrieved cases (e.g., the absence of key malicious indicators present in the retrieved attack patterns). This design reflects the principle that close retrieval matches constitute preliminary evidence of malicious intent.

Prompt template for zero-shot detection

Input:
* Current transaction: {system_input}

You are an expert in smart contract attack detection. Evaluate whether the current transaction is malicious based only on the provided transaction data.
There is no prior knowledge or historical context provided. Following the instructions:
1. Your judgment must be based purely on the internal logic, security best practices, and execution behavior of the current transaction.
2. Assume the transaction is Benign unless verifiable security flaws or abnormal logic are evident in the input.

Output MUST begin with a short answer 'Attack' or 'Benign', followed by below information:
1. *Behavior Summary*: Describe the transaction's overall behavior, including contract interactions and fund movements.
2. *Call Sequence Analysis*: Analyze the function call sequence. Highlight unusual operations or patterns violating smart contract security practices (e.g., state change before external call).
3. *Malicious Indicators*: Identify behaviors indicating an attack (e.g., reentrancy, unprivileged function calls, unauthorized balance changes) OR explain why the transaction is logically sound (if Benign).

Fig. 3. Prompt template for zero-shot detection.

When no cases pass the similarity threshold, TxShield falls back to zero-shot analysis. The prompt includes only the current transaction data and general instructions for identifying suspicious patterns (e.g., reentrancy signatures, abnormal fund flows, unauthorized privilege escalation). In contrast to retrieval-augmented prompting, the zero-shot prompt adopts a conservative stance, presuming the transaction to be benign unless verifiable security flaws or anomalous execution logic are evident in the trace. This asymmetric design reflects the absence of corroborating historical evidence: without retrieval-based grounding, aggressive suspicion would increase false positives. This path handles novel attack types that lack historical analogues in the knowledge base.

Both prompts require the LLM to produce structured output comprising four components:

(1) *Decision*: a binary label (`Attack` or `Benign`).
(2) *Behavior Summary*: a description of the transaction's contract interactions and fund movements.
(3) *Call Sequence Analysis*: an examination of function call patterns. Under retrieval augmentation, this involves comparative analysis against retrieved historical cases with an explicit assessment of behavioral correspondence; under zero-shot prompting, an independent identification of security-relevant patterns.
(4) *Malicious Indicators*: specific behaviors that support the decision.

The decision field records the initial LLM judgment; the final system label is determined after XGBoost filters the attack candidates.

The specific prompt templates are illustrated in Figures 2 and Figures 3: the former presents the context-aware detection prompt, which leverages retrieved historical attack instances for few-shot in-context learning; the latter details the zero-shot detection prompt, designed to evaluate transaction semantics autonomously when relevant historical references are absent. By decoupling the reasoning logic into retrieval-augmented and zero-shot prompting, TxShield maintains high precision for known threats while preserving the flexibility to detect novel attack types. The structured analysis fields make the LLM's reasoning process transparent, enabling security analysts to inspect the evidence chain underlying each decision.

5.3 Post-filtering with XGBoost

XGBoost checks LLM-generated attack candidates against numerical features of their execution traces. This filter supplements the LLM's semantic analysis with call structure, operation indicators, and value measurements, providing a second check before an attack is reported (Figure 1).

The 14 candidate features describe three aspects of a transaction. Call structure is represented by call count, event count, maximum call depth, and unique contract count. Operation indicators record transfer, approve, flashloan, delegatecall, selfdestruct, and high-value activity. Value and signature features comprise total and maximum call-node value, unique signature count, and unknown signature count. Features with zero importance are removed during selection. Call-node values measure native transfers rather than normalized ERC-20 asset flows.

To assess the value of LLM reasoning, we compare the complete pipeline with an XGBoost-only baseline that classifies transactions directly from numerical features. Section 6 describes this baseline and its performance.

6 Evaluation

To rigorously assess the performance of TxShield, we evaluate four research questions:

- **RQ1 (Effectiveness)**: How effectively does TxShield perform relative to state-of-the-art methods in attack detection?
- **RQ2 (Ablation Study)**: How significantly do different components contribute to the system's performance?
- **RQ3 (Sensitivity Analysis)**: How sensitive is TxShield to selection of different LLM backbones?
- **RQ4 (Efficiency)**: How efficient are TxShield in terms of computational resources and time?

Benchmark. We evaluate TxShield on two well-studied datasets: *DeFiAttackBench* for general DeFi attack detection and *PriceAttackBench* curated for price manipulation detection. Specifically, DeFiAttackBench includes 364 previously reported malicious transactions from public incidents recorded by DeFiHackLabs [34] between January of 2021 and January of 2025, which involves 110+ labeled exploit types across different blockchains such as Ethereum, BSC, and Arbitrum. Figure 4 shows the attack distribution and their proportions. Bussiness logic flaws and price-related attacks are the most common, accounting for 34.3% and 17.9% of the dataset, respectively. Reentrancy and call attacks, access control vulnerabilities, input validation issues, flashloan-driven attacks, mathematical calculation issues, token mechanism vulnerabilities, and other miscellaneous attack types make up the remaining 47.8%. It is believed that the diversity of attack types in DeFiAttackBench is representative of the broader DeFi ecosystem, providing a comprehensive benchmark for evaluating detection methods. For fair comparison, we curated a balanced dataset that contains 364 benign transactions that were sampled from normal user transactions of the

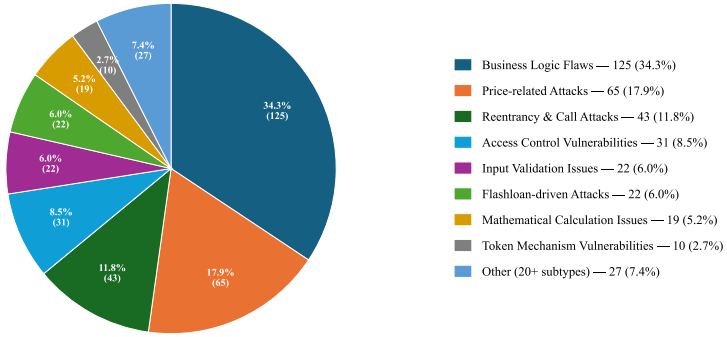


Fig. 4. Attack Distribution in DeFiAttackBench Dataset

victim protocols and filtered by temporal proximity. Therefore, the final DeFiAttackBench dataset contains 728 transactions, evenly split between 364 attack and 364 benign samples.

As price manipulation is one of the most prevalent attack types in DeFi era, we also evaluate TxShield on PriceAttackBench, which was first released with DeFiScope [48], that contains 95 real-world price manipulation cases and cause $381.16M total loss. Among them, we were unable to parse transaction data for four cases, resulting in 91 price manipulation-related transactions in PriceAttackBench for evaluation.

Baselines. To the best of our knowledge, TrxGNNBERT [24], TxSpector [46], Blockscan [40], DeFiScope [48], DeFort [42], DeFiRanger [39], and DeFiTainter [30] are the most relevant and representative baselines for our evaluation. Particularly, TrxGNNBERT [24] powered by a Graph-Transformer architecture, TxSpector [46] leveraging static opcode analysis, and Blockscan [40] using BERT model enhanced with masked language modeling mechanism, are evaluated on DeFiAttackBench dataset. For specialized price manipulation detectors, DeFiScope [48] combining fine-tuning and pattern learning, DeFort [42] harnessing symbolic execution and runtime monitoring, and DeFiRanger [39], and DeFiTainter [30] based on a inter-contract taint analysis, are evaluated on PriceAttackBench dataset. XGBoost-only classifies transactions from numerical features without retrieval or LLM inference. We use it to compare direct numerical classification with the complete detection pipeline.

Experiment Setup. LLMs are accessed through third-party APIs. We implement the pipeline with LangChain [21], Chroma [6], and Jina Embeddings v3 [32]. Kimi-k3 is the default backbone for DeFiAttackBench effectiveness and ablation experiments; DeepSeek-v4-pro and GPT-5.6-luna provide two further complete evaluations. Each of these three configurations processes all 728 transactions. We treat attacks as the positive class and report accuracy, precision, recall, and F1. For configurations with invalid outputs, metrics are computed on valid predictions and accompanied by prediction coverage.

The XGBoost-only baseline uses 420 training samples and 728 test samples, with balanced attack and benign classes in each set. The tree settings are maximum depth 3, learning rate 0.02, and minimum child weight 1. Row and column subsampling ratios are 0.9 and 0.7; L_1 and L_2 regularization coefficients are 0 and 0.5.

Table 1. Detection performance on DeFiAttackBench. TxShield and XGBoost-only use 364 attack and 364 benign samples. Metrics are percentages.

Method	N	TP	FP	TN	FN	Acc.	Prec.	Rec.	F1
TxSpector	450	117	117	128	88	54.4	50.0	57.1	53.3
TrxGNNBERT	728	288	91	264	85	75.9	76.0	77.3	76.6
Blockscan	728	255	12	352	109	83.4	95.5	70.1	81.0
XGBoost-only	728	323	60	304	41	86.13	84.33	88.74	86.48
TxShield (Kimi-k3)	728	322	7	357	42	93.27	97.87	88.46	92.93

TxSpector covers 450/728 cases. The TrxGNNBERT counts correspond to 373 attacks and 355 benign samples, rather than 364/364; its metrics are reported on that class composition. Runtime is analyzed separately in RQ4.

Table 2. Detection performance on 91 PriceAttackBench attacks.

Tool	#Attack	Detection Rate	ΔDetection Rate
DeFort (DF)	50	54.95%	−25.27%
DeFiRanger (DR)	48	52.75%	−27.47%
DeFiTainter (DT)	32	35.16%	−45.06%
DeFiScope (DS)	73	80.22%	**Baseline**
TxShield	86	94.51%	+14.29%

6.1 RQ1 (Effectiveness): Comparative Analysis of Detection Accuracy

To provide a comprehensive assessment of TxShield's detection efficacy, we conducted comparative experiments across two datasets with distinct characteristics. TxShield reduces false alarms while maintaining recall close to XGBoost-only (Table 1). With Kimi-k3, it correctly classifies 679 of 728 transactions and achieves 92.93% F1, compared with 86.48% for XGBoost-only. Precision rises from 84.33% to 97.87%, and false positives fall by 88.33% (60 to 7), with one additional false negative (41 to 42). XGBoost-only achieves a test AUC of 0.9467. Comparisons with the external baselines are descriptive because their evaluation coverage and class composition differ.

The external baselines show different detection trade-offs. Blockscan achieves 95.5% precision but 70.1% recall, missing 109 attacks; its F1 is 81.0%. TrxGNNBERT reports 76.6% F1, while TxSpector achieves 53.3% F1 on the 450 transactions it processes. The Kimi-based system combines 97.87% precision with 88.46% recall. Relative to Blockscan, this balance corresponds to both fewer false positives (7 versus 12) and fewer missed attacks (42 versus 109).

On PriceAttackBench, TxShield detects 86 of 91 attacks, achieving 94.51% recall compared with 80.22% for DeFiScope (Table 2). The PriceAttackBench experiment evaluates specialized price-manipulation detection separately from the Kimi-based DeFiAttackBench experiment. Table 3 lists the five missed cases.

Table 3. Missed price-manipulation attacks and baselines' detection results.

Attack Case	DS	DT	DF	DR
MerlinLab	✓	✗	✗	✗
BeltFinance_1	✓	✓	✗	✓
BeltFinance_2	✓	✓	✗	✓
IndexedFinance	✗	✗	✗	✓
ERC20TokenBank	✓	✗	✗	✓

DS=DeFiScope, DT=DeFiTainter, DF=DeFort, DR=DeFiRanger. ✓=detected, ✗=missed.

Table 4. Kimi-k3 ablation results. Metrics are percentages on valid predictions; counts are ordered TP/FP/TN/FN.

Configuration	N	TP/FP/TN/FN	Acc.	Prec.	Rec.	F1
Full system	728	322/7/357/42	93.27	97.87	88.46	92.93
w/o XGBoost	728	295/98/266/69	77.06	75.06	81.04	77.94
w/o XGBoost + two-stage	728	315/110/254/49	78.16	74.12	86.54	79.85
w/o RAG	726	278/98/266/84	74.93	73.94	76.80	75.34

The third row jointly removes XGBoost and two-stage retrieval. No-RAG coverage is 726/728 (99.73%); two invalid outputs are excluded. Comparisons measure end-to-end differences between variants.

The five missed price-manipulation attacks expose challenges in recognizing protocol-specific economic logic and multi-step interactions.

A deep dive into these misjudgments reveals that TxShield's limitations are primarily confined to four scenarios. First are rare or highly customized oracle manipulation patterns (e.g., MerlinLab), which exploit idiosyncratic oracle update windows; the absence of sufficiently similar historical samples causes analogical reasoning to falter. Second, the system struggles with arbitrage attacks involving complex multi-step cross-contract interactions (e.g., BeltFinance), where attackers leverage minute price discrepancies through sequences of transactions that appear legitimate in isolation, making full-chain reconstruction difficult. Third, novel attacks utilizing innovative mechanisms (e.g., IndexedFinance), such as exploiting index token rebalancing weights, fall outside the scope of historical patterns or rule-based detection. Finally, atypical price manipulation edge cases (e.g., ERC20TokenBank) manipulate internal accounting logic rather than liquidity pool pricing, a paradigm shift that often leads to omissions by most detection tools.

Answer to RQ1

With Kimi-k3, TxShield achieves 92.93% F1 and 97.87% precision. Compared with direct XGBoost classification, it reduces false positives from 60 to 7 with one additional false negative. On PriceAttackBench, recall reaches 94.51%.

6.2 RQ2 (Ablation Study): Effects of Component Configurations

We use Kimi-k3 to compare the complete system with three ablated configurations: without XGBoost, without both XGBoost and two-stage retrieval, and without RAG. The first two ablated configurations yield valid predictions for all 728 transactions. The no-RAG configuration yields 726 valid predictions; its two invalid outputs correspond to attacks.

XGBoost post-filtering. Relative to the no-XGBoost variant, the complete system produces 91 fewer false positives and detects 27 more attacks. These differences correspond to gains of 14.99 F1 points, 22.81 precision points, and 7.42 recall points. The changes between runs comprise 93 corrected and two newly introduced false positives, together with 39 recovered and 12 newly missed attacks.

Two-stage retrieval. In the absence of XGBoost, the run retaining two-stage retrieval achieves 77.94% F1, whereas the joint-removal configuration achieves 79.85%. Retaining two-stage retrieval therefore corresponds to 1.91 points lower F1 in this comparison. Its precision is slightly higher (75.06% versus 74.12%), but recall is lower (81.04% versus 86.54%). The complete system exceeds the joint-removal variant by 13.08 F1 points.

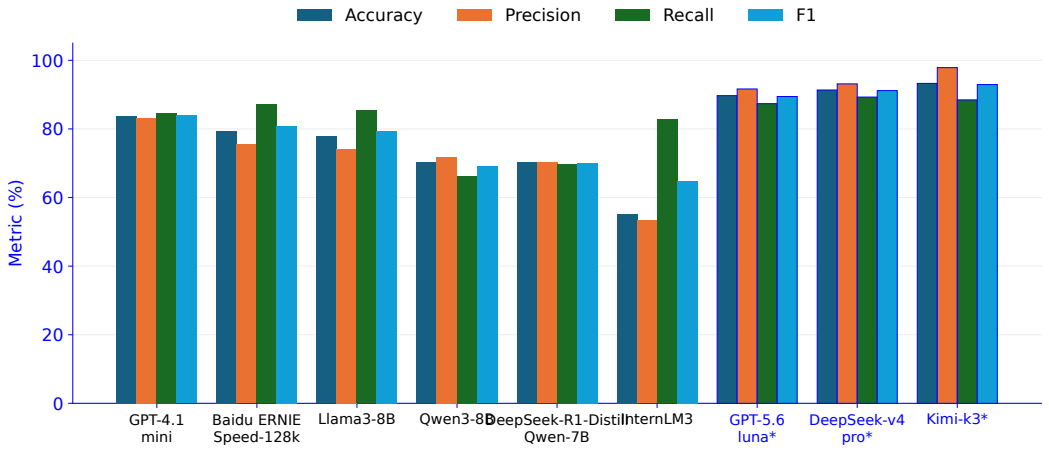


Fig. 5. Detection performance across nine LLM backbones on DeFiAttackBench. Asterisks identify the Kimi-k3, DeepSeek-v4-pro, and GPT-5.6-luna post-filtered configurations, each evaluated on all 728 transactions. Metrics are percentages.

No-RAG comparison. On the 726 transactions with valid predictions in both configurations, the complete system achieves 92.89% F1, compared with 75.34% without RAG, a difference of 17.55 percentage points.

Answer to RQ2

The complete Kimi configuration exceeds the no-XGBoost configuration by 14.99 F1 points and the no-RAG configuration by 17.55 points on their shared valid samples. Without XGBoost, two-stage retrieval trades higher precision for lower recall and F1.

6.3 RQ3 (Sensitivity Analysis): Choice of LLM Backbone

Among the three complete post-filtered evaluations, Kimi-k3 produces the fewest false positives, while DeepSeek-v4-pro detects the most attacks. Kimi-k3 achieves the highest precision and F1, with seven false positives. DeepSeek-v4-pro detects 325 attacks compared with Kimi-k3's 322, but produces 24 false positives. GPT-5.6-luna detects 318 attacks and produces 29 false positives. Figure 5 places these results alongside the six other backbone evaluations; Table 5 gives their detailed metrics.

The six-model comparison in Figure 5 also illustrates how backbone choice changes the precision–recall balance. Within that comparison, GPT-4.1-mini achieves the highest F1 (83.9%), with 83.2% precision and 84.6% recall. Baidu ERNIE-Speed-128k and Llama3-8B reach higher recall (87.1% and 85.4%), but lower precision (75.5% and 74.1%), yielding F1 scores of 80.9% and 79.3%, respectively. These measurements and the three post-filtered evaluations describe their respective experimental settings; the fixed-Kimi comparison in RQ2 examines component removal.

Prediction coverage. The Qwen3-8B post-filtered configuration yields 588 valid predictions (80.77% coverage): TP=293, FP=97, TN=162, and FN=36. F1 on this subset is 81.50%; the remaining 140 transactions comprise 35 attacks and 105 benign samples. Table 6 reports the separate experiments without XGBoost, including valid sample counts.

Table 5. Complete post-filtered backbone results ($N = 728$ each). Metrics are percentages.

Backbone	TP	FP	TN	FN	Acc.	Prec.	Rec.	F1
Kimi-k3	322	7	357	42	93.27	97.87	88.46	92.93
DeepSeek-v4-pro	325	24	340	39	91.35	93.12	89.29	91.16
GPT-5.6-luna	318	29	335	46	89.70	91.64	87.36	89.45

Table 6. Backbone performance without XGBoost. Metrics are percentages on valid predictions; valid sample counts indicate coverage.

Backbone/configuration	Valid/728	Acc.	Prec.	Rec.	F1
BAIDU	727	79.23	75.42	86.81	80.72
GPT-4.1-mini (no RAG)	728	55.36	80.00	14.29	24.24
GPT-4.1-mini (RAG)	728	80.91	77.11	87.91	82.16
InternLM3	682	58.80	53.27	94.65	68.18
Llama3-8B	726	77.69	73.81	85.64	79.28
Qwen3-8B	620	81.94	78.88	83.28	81.02
DeepSeek-R1	682	74.78	70.17	79.87	74.71

Answer to RQ3

Kimi-k3 provides the highest F1 (92.93%) and precision (97.87%) among the three complete post-filtered configurations, while DeepSeek-v4-pro provides the highest recall (89.29%). This trade-off allows backbone selection to reflect the relative costs of false alarms and missed attacks.

6.4 RQ4 (Efficiency): Practical Latency, Cost Analysis, and Deployment Viability

Table 7 reports latency and API cost for its six named backbones. The efficiency evaluation covers a different set of backbones from the three complete post-filtered evaluations in Table 5.

Having established the detection efficacy and structural integrity of TxShield, we now pivot to its pragmatic engineering feasibility. In the high-stakes domain of smart contract security, the real-world utility of any monitoring system is strictly governed by its operational latency and resource overhead. To ascertain whether TxShield can be seamlessly integrated into live threat-detection pipelines, we evaluate its performance across two pivotal dimensions: temporal efficiency and economic sustainability.

As evidenced by the performance metrics in Table 7, TxShield demonstrates a promising throughput suitable for near-real-time analysis. The system achieves an average end-to-end latency of 15.02 seconds when utilizing GPT-4.1-mini. This can be further optimized to 11.82 seconds with Llama-3.1-8B-Instruct and 12.66 seconds with Baidu ERNIE-Speed-128k. Such efficiency is largely underpinned by the optimized synergy between the RAG engine and our two-stage retrieval mechanism, a design choice that drastically prunes the search space before Large Language Model (LLM) inference begins. Notably, the retrieval stage itself (vector search followed by filtering) completes in under 100ms. Our profiling reveals that peak latencies are primarily driven by LLM inference cycles and network propagation during API calls, rather than internal computational bottlenecks like vector database queries or context distillation.

We conducted a granular assessment of operational expenditures across both datasets, as detailed in Table 7. For the relatively compact PriceAttackBench dataset (91 samples), GPT-4.1-mini consumed approximately 5.43 million tokens at a cumulative cost of $2.24, whereas GPT-3.5-Turbo

Table 7. Runtime and API cost of TxShield for the evaluated backbone configurations.

Model	Tokens	Cost($)	Avg. Time (s)
PriceAttackBench (91 samples)			
GPT-4.1-mini	5.43M	2.24	N/A
DeFiAttackBench (728 samples)			
GPT-4.1-mini	8.62M	3.86	15.02
Llama-3.1-8B-Instruct	8.28M	0.26	11.82
Baidu ERNIE-Speed-128k	11.62M	FREE	12.66
InternLM3-8B-Instruct	8.2M	FREE	12.70
DeepSeek-R1-Distill-Qwen-14B	7.7M	FREE	32.31
Qwen3-8B	8.15M	FREE	37.54

Note: Costs are estimated from public API rates; token counts are total input+output per query, as reported by the API providers.

required 5.87 million tokens, totaling $3.15. Scaling the evaluation to the more extensive DeFiAttackBench dataset (728 samples) unveiled distinct efficiency profiles among the models. While GPT-4.1-mini processed the entire corpus for $3.86, the Llama-3.1-8B-Instruct model demonstrated the capacity to slash costs to roughly $0.26, a reduction of over 93%.

To better understand the cost characteristics of different models, we analyzed token consumption during live API evaluation. The results indicate that model-specific verbosity remains a key factor shaping overall token usage. Qwen3-8B produced comparatively longer responses, with outputs reaching up to 29 KB (approximately 7,400 tokens), resulting in a total of 8.15M tokens. InternLM3-8B-Instruct generated more compact outputs, though its total volume (8.2M tokens) remained similar due to retrieval-induced input overhead. DeepSeek-R1-Distill-Qwen-14B exhibited the highest efficiency among the evaluated models, with a total of 7.7M tokens. These observations highlight the combined influence of output verbosity and retrieval context on API-level cost.

While our evaluation primarily focuses on Ethereum and BSC, where most attack cases are currently observed, TxShield is designed to be extendable to other EVM-compatible blockchains, such as Polygon and Arbitrum. This adaptability ensures that the framework remains applicable as malicious activities evolve and expand across different blockchain ecosystems.

As shown in Table 7, such discrepancies, where output volumes vary by a factor of three for identical retrieval-augmented queries, underscore the critical impact of model selection on a system's economic viability. Crucially, the stable and economical output characteristics of models like InternLM3-8B-Instruct suggest that by prioritizing token efficiency without sacrificing analytical depth, the TxShield framework can achieve a high degree of financial sustainability. Furthermore, the convergence of low operational cost ($0.26) and competitive latency (11.82 seconds) positions Llama-3.1-8B-Instruct as a particularly compelling candidate for practical deployment. These empirical findings collectively reinforce the prospect of deploying TxShield in high-frequency production environments where both precision and cost-efficiency are paramount.

Answer to RQ4

TxShield demonstrates practical viability for near-real-time DeFi attack detection, achieving average latencies of 11.82 to 15.02 seconds across different LLM backbones. Cost analysis reveals that while GPT-4.1-mini incurs higher expenses ($3.86 for 728 samples), models like Llama-3.1-8B-Instruct can reduce costs to $0.26 without significant performance loss. These findings highlight TxShield's adaptability to various operational constraints, balancing speed, accuracy, and economic efficiency for deployment in production environments.

6.5 Discussion: Operational Boundaries and Capability Spectrum

The category-level evaluation examines how attack mechanisms affect detection. Its rates are separate measurements from the aggregate Kimi-k3 results in RQ1–RQ3. To better understand the operational boundaries of TxShield, we conducted a systematic analysis of its detection performance across the DeFiAttackBench dataset, specifically examining the interplay between attack mechanisms and technical features. Our findings reveal that TxShield's efficacy is distributed across a distinct spectrum, primarily dictated by three core dimensions: the observability of malicious behavior, the analogicality of semantic patterns, and the contextual dependency of the attack logic. This spectrum not only defines the current capability limits of TxShield but also provides critical insights for its real-world deployment and future iteration. Table 8 summarizes the detection performance across different attack categories.

To characterize TxShield's capability boundaries, we organize attacks along three dimensions that align with its decision pipeline: (i) *trace-level behavioral evidence*, (ii) *retrieval-based analogy to historical cases*, and (iii) *multi-step/cross-contract context integration*. Specifically, *Observability* measures whether execution traces expose discriminative behavioral deviations (e.g., anomalous external-call/state-update patterns); *Analogicality* measures whether such deviations form reusable semantic templates that can be matched to prior incidents in the knowledge base; *Contextual dependency* measures the extent of global context required to infer intent, especially when signals are distributed across long, multi-step, or cross-contract interactions. Based on these dimensions, Table 8 summarizes a capability spectrum: categories dominated by observable and reusable patterns are easier to detect, whereas categories requiring broad context integration or exhibiting behaviorally compliant traces approach the system's natural boundary.

We label each category in Table 8 by the primary bottleneck it presents to TxShield. **Low**: high observability and strong analogicality (clear, repetitive trace signatures). **Medium**: observable core semantics but weaker reusability due to protocol-specific or highly variable logic (analogy-dependent). **High**: strong contextual dependency, where intent emerges only after aggregating evidence across long, multi-step, or cross-contract execution chains. **Fundamental**: low observability at the trace-semantic level, where execution remains behaviorally compliant and the malice stems from cryptographic or protocol-assumption violations beyond behavior-only semantics.

TxShield demonstrates its most resilient detection capabilities in scenarios where behavioral anomalies are highly observable and semantic patterns remain stable and reusable. Typical examples include classic reentrancy exploits (96.2%), flash-loan price manipulations (91.7%), and price/oracle manipulations (93.2%). These attacks generate explicit, identifiable signatures within the execution flow, such as the "unprivileged call to privileged function" pattern seen in the LocalTrader series, or the "unexpected state change following an external call" characteristic of the SpankChain reentrancy exploit. Because the core malicious semantics of these attacks are highly repetitive, TxShield can leverage its historical case library to establish a robust mapping between "symptoms"

Table 8. Detection rates in the category-level evaluation.

Type	Detection Rate	Difficulty
Reentrancy	96.2%	Low
Price & Oracle Manipulation	93.2%	Low
Flash-loan Price Manipulation	91.7%	Low
Business Logic Flaws	89.6%	Medium
Liquidity & Migration Exploits	87.5%	Medium
Arbitrary Call / External Call	86.7%	Medium
Access Control	79.3%	Medium
Fake Market / MEV / Sandwich Attacks	75.0%	High
Signature & Validation Issues	57.1%	High
Cryptographic Exploits	<50%	Fundamental

Note: Cross-contract reentrancy exploits are merged into Reentrancy due to limited samples (2 cases).

and "attack types." Consequently, even when encountering novel variants, the system maintains high detection rates through stable pattern matching.

Moving into the domain of common but more sophisticated DeFi exploits—such as Access Control (79.3%), business logic flaws (89.6%), arbitrary external calls (86.7%), liquidity/migration exploits (87.5%), reflection/token economics flaws, and storage/proxy issues—the system's performance begins to exhibit fluctuations influenced by the complexity and novelty of the attack patterns. In this domain, TxShield effectively identifies signatures such as the "unprivileged call to privileged function" pattern (e.g., LocalTrader series) or anomalous asset transfer sequences when the knowledge base contains analogous patterns (e.g., Platypus attack). However, performance is challenged by highly innovative or combinatorial variants. For instance, the Indexed Finance exploit utilized a then-novel index token weight rebalancing mechanism; the absence of directly comparable cases in the knowledge base can lead to false negatives. Similarly, variants employing non-standard mechanisms—such as the UwU Lend exploit's use of median pricing across multiple pools—require the underlying LLM to perform deep reasoning over novel logic rather than simple pattern matching. This area represents a transition for TxShield from "pattern matching" to "semantic comprehension," where accuracy is strictly gated by the breadth of the knowledge base and the model's reasoning depth.

A more pronounced performance degradation is observed in attacks where malicious intent is decoupled from immediate actions or dispersed across long, complex execution chains. Cross-contract exploits (e.g., Rari Capital, merged into Reentrancy), signature and validation issues (57.1%), and fake market/MEV/sandwich attacks (75.0%) exemplify this challenge. The core difficulty lies in the fragmentation of semantic signals: malicious intent is often distributed across multiple contracts or embedded within sequences of seemingly legitimate operations, creating a bottleneck for contextual integration. Intent typically becomes discernible only after aggregating evidence across disparate calls, such as missing `ecrecover`, replay patterns, MEV ordering, or long-range state effects. Although TxShield's retrieval module can surface localized anomalous fragments, its ability to reconstruct a holistic cross-contract call-graph and synthesize these dispersed signals into a coherent attack narrative remains limited, resulting in lower detection rates (approximately 57%–75%).

At the furthest periphery of this capability spectrum lie attacks that manifest no distinguishable behavioral deviations, such as cryptographic exploits (< 50%) or pseudo-randomness prediction exploits. Here, TxShield encounters a fundamental boundary. In these cases, such as integer overflow/underflow in legacy Solidity versions, precision loss, or signature malleability, the execution traces remain strictly compliant with EVM semantics, while the malice is rooted in the abuse of

cryptographic primitives or the violation of underlying protocol-level assumptions that are not explicitly reflected in the execution trace. This limitation is not unique to TxShield but is inherent to all detection methodologies based on behavioral semantics. It clearly defines the system's natural domain: it excels at detecting "behaviorally anomalous" exploits but is inherently blind to "compliant yet malicious" logic. Transcending this boundary would necessitate the integration of complementary paradigms, such as formal verification.

Furthermore, the emergence of hybrid attack vectors and novel mechanisms, such as those associated with the DN404 token standard in 2023–2024, highlights the ongoing challenge of system adaptation. Detection rates for these nascent threats are slightly lower than for mature attack types, underscoring TxShield's dependence on the temporal relevance and coverage of its knowledge base. Hybrid exploits, such as the Game_exp attack, which simultaneously leveraged reentrancy and business logic flaws, require an understanding of the synergy between different vulnerability types rather than the isolated identification of single features, posing a unique challenge to current retrieval-based methods.

In conclusion, the capability spectrum of TxShield provides empirical evidence for the value of semantic-based DeFi security detection. Its performance is most significant in scenarios with clear behavioral patterns and sufficient historical analogies, making it a powerful core for automated defense. However, the identified limitations in global context integration and behaviorally compliant exploits reveal the insufficiency of a singular methodology. These findings suggest a clear evolutionary path: enhancing the detection of complex attacks requires more sophisticated call-graph analysis and state-propagation modeling; maintaining responsiveness to new threats demands dynamic, automated knowledge base expansion; and breaking fundamental boundaries will require a multi-modal collaborative framework that fuses TxShield's behavioral analysis with formal verification and symbolic execution. Ultimately, TxShield serves as a modular foundation for a next-generation, multi-layered defense architecture capable of covering a more complete attack surface.

7 Related Work

On-chain Security and Program Analysis. The immutability of deployed smart contracts has driven extensive research on on-chain security analysis, broadly encompassing pre-deployment verification and post-deployment transaction monitoring. Pre-deployment approaches rely on static analysis and formal verification, with symbolic execution tools such as Oyente [23] and Maian [27], and mature frameworks like Slither [11] and Mythril [10], enabling automated detection of common vulnerabilities. Formal methods, including Certora Prover [19] and KEVM [18], further strengthen correctness guarantees by reasoning over mathematically precise semantics. However, static analysis is fundamentally constrained by path explosion and its inability to capture the non-deterministic, evolving global state of blockchain systems, particularly in DeFi environments characterized by composability [49] and gas-related vulnerabilities [15]. These limitations have motivated post-deployment transaction analysis, where graph-based methods, machine learning techniques [35], and forensic tools such as TXSPECTOR [46] are used to identify malicious behaviors including Ponzi schemes and flash-loan-based attacks [7]. Nevertheless, existing dynamic approaches largely depend on predefined heuristics, leaving open the challenge of detecting malicious interactions that remain syntactically compliant yet exploit subtle business logic manipulations.

LLMs for Code and Security Analysis. The emergence of Large Language Models (LLMs) has initiated a paradigm shift in smart contract auditing, steering the field away from rigid pattern matching toward nuanced semantic inference. Early breakthroughs were rooted in representation learning, where models like CodeBERT [12] and SmartBERT demonstrated a profound capacity for capturing program control flows and semantics through domain-specific pre-training. Building

upon this foundation, the focus has shifted toward fine-grained defect localization, with models such as VulBERTa [17] and LineVul [13] significantly enhancing the precision of vulnerability prediction.

More recently, LLM-driven frameworks like GPTScan [33] have begun integrating reasoning capabilities—often enhanced by Chain-of-Thought (CoT) prompting [38]—with program analysis to validate potential attack vectors. Nevertheless, deploying LLMs in the high-stakes DeFi environment is not without its perils. The most pervasive challenge is the phenomenon of "hallucinations", wherein models generate plausible yet technically erroneous vulnerability reports [5]. Furthermore, the inherent "knowledge cutoff" of pre-trained models renders them blind to zero-day exploits and rapidly evolving protocol patterns. This lack of interpretability, often referred to as the "black-box" nature of LLMs [20], and their performance degradation when operating outside their "comfort zone" [16], further complicates their adoption by security professionals who require verifiable evidence for decision-making.

RAG in Software Engineering and Security. To mitigate the inherent limitations of static parameters, Retrieval-Augmented Generation (RAG) has surfaced as a cornerstone for building knowledge-intensive security systems [22]. By bridging the gap between a model's parametric memory and non-parametric external databases, RAG effectively anchors LLM outputs in real-world facts, thereby enhancing both temporal relevance and factual accuracy.

While the efficacy of RAG has been validated in broader cybersecurity tasks—ranging from repository-level code completion in RepoCoder [45] and documentation-driven generation in DocPrompting [50] to LLM-empowered penetration testing in PentestGPT [9]—its application within the smart contract domain remains in its infancy. Preliminary efforts have begun utilizing retrieval mechanisms to assist in generating security invariants, such as SmartInv [36]; however, a significant research gap persists: the absence of a dynamic, temporal knowledge base designed for real-time attack detection. Conventional RAG implementations are largely static, prioritizing isolated code snippets over the multi-dimensional context of live transactions, such as state transitions and economic repercussions.

This study addresses this gap by introducing a Semantically-Enhanced Temporal Transaction Knowledge Base. Unlike previous tools that retrieve disparate code blocks, our framework retrieves historically confirmed attack sequences, allowing the system to perform behavior-level analogical reasoning. By analyzing the semantic alignment between real-time transaction streams and historical exploit trajectories, our method can identify novel variants that share the same underlying malicious logic as past attacks, even when their syntactic features differ entirely. This provides a proactive, "history-driven" defense layer, effectively filling the void between static code analysis and reactive pattern matching.

8 Conclusion

We presented TxShield, a retrieval-augmented generation (RAG) framework for DeFi attack detection that addresses key limitations of existing approaches. TxShield constructs an incrementally expandable knowledge base of historical attacks with behavioral summaries, employs a two-stage retrieval mechanism with dynamic similarity thresholding, applies adaptive prompting strategies, and incorporates XGBoost post-filtering. Together, these components bridge the gap between low-level execution traces and high-level attack semantics, while mitigating LLM hallucinations via evidence-grounded reasoning.

With Kimi-k3, TxShield achieves 92.93% F1 on 728 DeFiAttackBench transactions and reduces false positives from 60 to 7 compared with XGBoost-only, a 6.45-point F1 improvement. The complete system also exceeds the no-XGBoost Kimi variant by 14.99 F1 points. The retrieval ablation shows a narrower effect: without XGBoost, two-stage retrieval increases precision but

reduces recall and F1. The complementary price-manipulation evaluation detects 86 of 91 attacks. The combined pipeline uses historical attack evidence to support LLM analysis and numerical features to check its attack candidates. Its advantage over direct numerical classification is a substantial reduction in false alarms at comparable recall.

TxShield faces limitations in scenarios involving cryptographic exploits without behavioral signatures, complex multi-step cross-contract attacks with fragmented semantic signals, and truly novel attack patterns that are absent from the knowledge base. Future work includes integrating formal verification for cryptographic exploit detection, developing more sophisticated call-graph analysis for cross-contract reasoning, and implementing automated knowledge base expansion to remain responsive to emerging threats.

TxShield demonstrates that retrieval-augmented generation is a promising paradigm for security analysis tasks that require both domain knowledge and robust reasoning. As DeFi protocols continue to evolve, approaches that leverage accumulated security knowledge while adapting to new patterns will be essential for protecting the assets at stake in this ecosystem.

9 Data Availability

The attack cases in DeFiAttackBench come from DeFiHackLabs. PriceAttackBench is released with DeFiScope [48]. The TxShield project repository is https://github.com/oumo0/TxShield.

References

[1] 2025. Crypto hacks hit $3.4 billion in 2025, attacks on individual wallets rise: Chainalysis. https://www.theblock.co/post/382477/crypto-hack-2025-chainalysis. Accessed: 2026-01.

[2] 2026. North Korea Drives Record $2 Billion Crypto Theft Year, Pushing All-Time Total to $6.75 Billion. https://www.chainalysis.com/blog/crypto-hacking-stolen-funds-2026/. Accessed: 2026-01-30.

[3] Aave. 2024. Aave Protocol Documentation: Flash Loans. https://docs.aave.com/developers/guides/flash-loans. Accessed: 2025-01-01.

[4] Hayden Adams, Noah Zinsmeister, Moody Salem, River Keefer, and Dan Robinson. 2021. Uniswap v3 Core. https://uniswap.org/whitepaper-v3.pdf.

[5] Emily M. Bender, Timnit Gebru, Angelina McMillan-Major, and Shmargaret Shmitchell. 2021. On the Dangers of Stochastic Parrots: Can Language Models Be Too Big?. In *Proceedings of the 2021 ACM Conference on Fairness, Accountability, and Transparency* (Virtual Event, Canada) *(FAccT '21)*. Association for Computing Machinery, New York, NY, USA, 610–623. doi:10.1145/3442188.3445922

[6] Chroma. 2024. Chroma: The AI-native Open-source Embedding Database. https://www.trychroma.com/. Accessed: 2025-01-01.

[7] Philip Daian, Steven Goldfeder, Tyler Kell, Yunqi Li, Xueyuan Zhao, Iddo Bentov, Lorenz Breidenbach, and Ari Juels. 2020. Flash Boys 2.0: Frontrunning in Decentralized Exchanges, Miner Extractable Value, and Consensus Instability. In *2020 IEEE Symposium on Security and Privacy (SP)*. 910–927. doi:10.1109/SP40000.2020.00040

[8] Christopher De Baets, Basem Suleiman, Armin Chitizadeh, and Imran Razzak. 2024. Vulnerability Detection in Smart Contracts: A Comprehensive Survey. *arXiv preprint arXiv:2407.07922* (2024).

[9] Gelei Deng, Yi Liu, Víctor Mayoral-Vilches, Peng Liu, Yuekang Li, Yuan Xu, Tianwei Zhang, Yang Liu, Martin Pinzger, and Stefan Rass. 2024. PentestGPT: An LLM-empowered Automatic Penetration Testing Tool. arXiv:2308.06782 [cs.SE] https://arxiv.org/abs/2308.06782

[10] ConsenSys Diligence. 2017. Mythril: Security Analysis Tool for Ethereum Smart Contracts. https://github.com/ConsenSysDiligence/mythril. Accessed: 2026-01-22.

[11] Josselin Feist, Gustavo Grieco, and Alex Groce. 2019. Slither: A Static Analysis Framework for Smart Contracts. In *2019 IEEE/ACM 2nd International Workshop on Emerging Trends in Software Engineering for Blockchain (WETSEB)*. 8–15. doi:10.1109/WETSEB.2019.00008

[12] Zhangyin Feng, Daya Guo, Duyu Tang, Nan Duan, Xiaocheng Feng, Ming Gong, Linjun Shou, Bing Qin, Ting Liu, Daxin Jiang, and Ming Zhou. 2020. CodeBERT: A Pre-Trained Model for Programming and Natural Languages. In *Findings of the Association for Computational Linguistics: EMNLP 2020*, Trevor Cohn, Yulan He, and Yang Liu (Eds.). Association for Computational Linguistics, Online, 1536–1547. doi:10.18653/v1/2020.findings-emnlp.139

[13] Michael Fu and Chakkrit Tantithamthavorn. 2022. LineVul: A Transformer-based Line-Level Vulnerability Prediction. In *2022 IEEE/ACM 19th International Conference on Mining Software Repositories (MSR)*. IEEE.

[14] F. Ghiyami Pour, G. Costa, and L. Galletta. 2025. Welcome Back: A Systematic Literature Review of Smart Contract Reentrancy and Countermeasures. *Blockchain: Research and Applications* (2025), 100347. doi:10.1016/j.bcra.2025.100347

[15] Neville Grech, Michael Kong, Anton Jurisevic, Lexi Brent, Bernhard Scholz, and Yannis Smaragdakis. 2018. MadMax: surviving out-of-gas conditions in Ethereum smart contracts. *Proc. ACM Program. Lang.* 2, OOPSLA, Article 116 (Oct. 2018), 27 pages. doi:10.1145/3276486

[16] Yuejun Guo, Constantinos Patsakis, Qiang Hu, Qiang Tang, and Fran Casino. 2024. Outside the Comfort Zone: Analysing LLM Capabilities in Software Vulnerability Detection. arXiv:2408.16400 [cs.CR] https://arxiv.org/abs/2408.16400

[17] Hazim Hanif and Sergio Maffeis. 2022. VulBERTa: Simplified Source Code Pre-Training for Vulnerability Detection. In *2022 International Joint Conference on Neural Networks (IJCNN)*. 1–8. doi:10.1109/IJCNN55064.2022.9892280

[18] Everett Hildenbrandt, Manasvi Saxena, Nishant Rodrigues, Xiaoran Zhu, Philip Daian, Dwight Guth, Brandon Moore, Daejun Park, Yi Zhang, Andrei Stefanescu, and Grigore Rosu. 2018. KEVM: A Complete Formal Semantics of the Ethereum Virtual Machine. In *2018 IEEE 31st Computer Security Foundations Symposium (CSF)*. 204–217. doi:10.1109/CSF.2018.00022

[19] Certora Inc. 2026. Certora Prover. https://www.certora.com/prover. Accessed: 2026-01-17.

[20] Avishree Khare, Saikat Dutta, Ziyang Li, Alaia Solko-Breslin, Rajeev Alur, and Mayur Naik. 2024. Understanding the Effectiveness of Large Language Models in Detecting Security Vulnerabilities. arXiv:2311.16169 [cs.CR] https://arxiv.org/abs/2311.16169

[21] LangChain. 2024. LangChain: Build Context-aware Reasoning Applications. https://www.langchain.com/. Accessed: 2025-01-01.

[22] Patrick Lewis, Ethan Perez, Aleksandra Piktus, Fabio Petroni, Vladimir Karpukhin, Naman Goyal, Heinrich Küttler, Mike Lewis, Wen tau Yih, Tim Rocktäschel, Sebastian Riedel, and Douwe Kiela. 2021. Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks. arXiv:2005.11401 [cs.CL] https://arxiv.org/abs/2005.11401

[23] Loi Luu, Duc-Hiep Chu, Hrishi Olickel, Prateek Saxena, and Aquinas Hobor. 2016. Making Smart Contracts Smarter. In *Proceedings of the 2016 ACM SIGSAC Conference on Computer and Communications Security* (Vienna, Austria) *(CCS '16)*. Association for Computing Machinery, New York, NY, USA, 254–269. doi:10.1145/2976749.2978309

[24] Wei Ma, Junjie Shi, Jiaxi Qiu, Cong Wu, Jing Chen, Lingxiao Jiang, Shangqing Liu, Yang Liu, and Yang Xiang. 2025. Detecting DeFi Fraud With a Graph-Transformer Language Model. *IEEE Transactions on Information Forensics and Security* 20 (2025), 10051–10065. doi:10.1109/TIFS.2025.3612184

[25] Wei Ma, Daoyuan Wu, Yuqiang Sun, Tianwen Wang, Shangqing Liu, Jian Zhang, Yue Xue, and Yang Liu. 2025. Combining Fine-Tuning and LLM-based Agents for Intuitive Smart Contract Auditing with Justifications. In *2025 IEEE/ACM 47th International Conference on Software Engineering (ICSE)*. IEEE, 1742–1754.

[26] Torgin Mackinga, Tejaswi Nadahalli, and Roger Wattenhofer. 2022. TWAP Oracle Attacks: Easier Done than Said? *IACR Cryptology ePrint Archive* (2022), 445.

[27] Ivica Nikolić, Aashish Kolluri, Ilya Sergey, Prateek Saxena, and Aquinas Hobor. 2018. Finding The Greedy, Prodigal, and Suicidal Contracts at Scale. In *Proceedings of the 34th Annual Computer Security Applications Conference* (San Juan, PR, USA) *(ACSAC '18)*. Association for Computing Machinery, New York, NY, USA, 653–663. doi:10.1145/3274694.3274743

[28] Marco Ortu, Giacomo Ibba, Giuseppe Destefanis, Claudio Conversano, and Roberto Tonelli. 2024. Taxonomic Insights into Ethereum Smart Contracts by Linking Application Categories to Security Vulnerabilities. *Scientific Reports* 14 (2024), 23433. doi:10.1038/s41598-024-73454-0

[29] Paradigm. 2024. Foundry: A Blazing Fast, Portable and Modular Toolkit for Ethereum Application Development. https://github.com/foundry-rs/foundry. Accessed: 2025-01-01.

[30] Shuo Peng, Zhenguang Tan, Zhuang Chen, Bifei Zhou, Xusheng Luo, Dong Zhang, and Jianhai Li. 2023. DeFiTainter: Detecting Price Manipulation Vulnerabilities in DeFi Protocols. In *Proceedings of the 32nd ACM SIGSOFT International Symposium on Software Testing and Analysis (ISSTA)*. 1144–1156. doi:10.1145/3597926.3598124

[31] Kaihua Qin, Liyi Zhou, Benjamin Livshits, and Arthur Gervais. 2020. Attacking the DeFi Ecosystem with Flash Loans for Fun and Profit. arXiv:2003.03810 [cs.CR] https://arxiv.org/abs/2003.03810

[32] Saba Sturua, Isabelle Mohr, Mohammad Kalim Akram, Michael Günther, Bo Wang, Markus Krimmel, Feng Wang, Georgios Mastrapas, Andreas Koukounas, Nan Wang, and Han Xiao. 2024. jina-embeddings-v3: Multilingual Embeddings With Task LoRA. arXiv:2409.10173 [cs.CL] https://arxiv.org/abs/2409.10173

[33] Yuqiang Sun, Daoyuan Wu, Yue Xue, Han Liu, Haijun Wang, Zhengzi Xu, Xiaofei Xie, and Yang Liu. 2024. GPTScan: Detecting Logic Vulnerabilities in Smart Contracts by Combining GPT with Program Analysis. In *2024 IEEE/ACM 46th International Conference on Software Engineering (ICSE)*. 2048–2060. doi:10.1145/3597503.3639117

[34] SunWeb3Sec. 2024. DeFiHackLabs: Reproduce DeFi Hacked Incidents Using Foundry. https://github.com/SunWeb3Sec/DeFiHackLabs. Accessed: 2025-01-01.

[35] Deguang Wang, Mengtao Shan, and Ning Tong. 2024. Smart Contract Vulnerability Detection Based on Machine Learning. In *2024 6th International Conference on Electronic Engineering and Informatics (EEI)*. 1038–1042. doi:10.1109/EEI63073.2024.10696331

[36] Sally Junsong Wang, Kexin Pei, and Junfeng Yang. 2024. SmartInv: Multimodal Learning for Smart Contract Invariant Inference. arXiv:2411.09217 [cs.SE] https://arxiv.org/abs/2411.09217

[37] Zexu Wang, Jiachi Chen, Yanlin Wang, Yu Zhang, Weizhe Zhang, and Zibin Zheng. 2024. Efficiently Detecting Reentrancy Vulnerabilities in Complex Smart Contracts. In *Proceedings of the ACM on Software Engineering*, Vol. 1. 161–181. doi:10.1145/3643734

[38] Jason Wei, Xuezhi Wang, Dale Schuurmans, Maarten Bosma, Brian Ichter, Fei Xia, Ed Chi, Quoc Le, and Denny Zhou. 2023. Chain-of-Thought Prompting Elicits Reasoning in Large Language Models. arXiv:2201.11903 [cs.CL] https://arxiv.org/abs/2201.11903

[39] Siwei Wu, Dabao Wang, Jianting He, Yajin Zhou, Lei Wu, Xingliang Yuan, Qinming He, and Kui Ren. 2021. DeFiRanger: Detecting Price Manipulation Attacks on DeFi Applications. arXiv:2104.15068 [cs.CR] https://arxiv.org/abs/2104.15068

[40] Xian Wu et al. 2025. BlockScan: Detecting Anomalies in Blockchain Transactions. In *Proceedings of the Neural Information Processing Systems (NeurIPS)*. https://github.com/nuwuxian/BlockScan Accepted at NeurIPS 2025.

[41] Rui Xi, Zehua Wang, and Karthik Pattabiraman. 2024. POMABuster: Detecting Price Oracle Manipulation Attacks in Decentralized Finance. In *2024 IEEE Symposium on Security and Privacy (SP)*. 1823–1841. doi:10.1109/SP54263.2024.00095

[42] Yuanliang Xie, Jiaming Chen, Zibin Ye, Yuefei Liu, Yinglong Chen, Zhenchang Yang, and Zibin Zheng. 2024. DeFort: Automatic Detection and Analysis of Price Manipulation Attacks in DeFi Applications. In *Proceedings of the 33rd ACM SIGSOFT International Symposium on Software Testing and Analysis (ISSTA)*. 1235–1247. doi:10.1145/3650212.3652137

[43] Yahoo Finance. 2025. DeFi Total Value Locked Surpasses $230 Billion in 2025. https://finance.yahoo.com/news/defi-tvl-hits-record-237b-181957477.html. Accessed: 2026-01.

[44] Shuo Yang, Jiachi Chen, Mingyuan Huang, Zibin Zheng, and Yuan Huang. 2024. Uncover the Premeditated Attacks: Detecting Exploitable Reentrancy Vulnerabilities by Identifying Attacker Contracts. In *Proceedings of the 46th IEEE/ACM International Conference on Software Engineering (ICSE)*. doi:10.1145/3597503.3639153

[45] Fengji Zhang, Bei Chen, Yue Zhang, Jacky Keung, Jin Liu, Daoguang Zan, Yi Mao, Jian-Guang Lou, and Weizhu Chen. 2023. RepoCoder: Repository-Level Code Completion Through Iterative Retrieval and Generation. arXiv:2303.12570 [cs.CL] https://arxiv.org/abs/2303.12570

[46] Mengya Zhang, Xiaokuan Zhang, Yinqian Zhang, and Zhiqiang Lin. 2020. TXSPECTOR: Uncovering Attacks in Ethereum from Transactions. In *29th USENIX Security Symposium (USENIX Security 20)*. USENIX Association, 2775–2792. https://www.usenix.org/conference/usenixsecurity20/presentation/zhang-mengya

[47] Ziyao Zhang, Yanlin Wang, Yan Xia, Xun Zhou, Ziyu Lyu, Guissart Matteo, Peng Liang, and Qing Wang. 2024. LLM Hallucinations in Practical Code Generation: Phenomena, Mechanism, and Mitigation. arXiv:2409.20550 [cs.SE] https://arxiv.org/abs/2409.20550

[48] Juantao Zhong, Daoyuan Wu, Ye Liu, Maoyi Xie, Yang Liu, Yi Li, and Ning Liu. 2025. Detecting Various DeFi Price Manipulations with LLM Reasoning. arXiv:2502.11521 [cs.CR] https://arxiv.org/abs/2502.11521

[49] Liyi Zhou, Xihan Xiong, Jens Ernstberger, Stefanos Chaliasos, Zhipeng Wang, Ye Wang, Kaihua Qin, Roger Wattenhofer, Dawn Song, and Arthur Gervais. 2023. SoK: Decentralized Finance (DeFi) Attacks. In *2023 IEEE Symposium on Security and Privacy (SP)*. 2444–2461. doi:10.1109/SP46215.2023.10179435

[50] Shuyan Zhou, Uri Alon, Frank F. Xu, Zhiruo Wang, Zhengbao Jiang, and Graham Neubig. 2023. DocPrompting: Generating Code by Retrieving the Docs. arXiv:2207.05987 [cs.CL] https://arxiv.org/abs/2207.05987